Risk Assessment Techniques

Identification · Qualitative & Quantitative Analysis · Threat & Vulnerability Assessment · Risk Register

Evidence collected from the live HVMC Azure tenant with Azure CLI on October 13, 2026

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Risk Assessment Techniques (Semester 4, Week 10)
Builds on	Risk Management Fundamentals (NIST RMF, governance, HIPAA matrix gaps G1–G8); Sept 8 vulnerability-based risk report
Companion file	**HVMC_Risk_Register.xlsx** — live risk register, change history, heat map, ALE calculator, checklist
Prepared By	Sabitha S Karanavar
Report Date	October 13, 2026

Rubric Cross-Reference

Rubric requirement	Section	Evidence
Structured risk identification using brainstorming, checklists and SWOT, with documented facilitation approach	1.1–1.4	Facilitated workshop plan and output; 27-item CIS-aligned checklist run against Azure (15 fails); SWOT; consolidation of all three into 16 risks
Qualitative analysis with 5×5 matrix and likelihood/impact scales	2	Defined 1–5 scales, heat map of all 16 risks, ranked list
Quantitative analysis with EMV and ALE and supporting data	3	ALE (SLE × ARO) for 5 top risks with before/after controls and ROSI; EMV decision tree for ransomware; data from IBM 2025 and HHS 2025 penalty figures
Threat and vulnerability assessment with documented findings	4	NIST SP 800-30 threat sources, MITRE ATT&CK threat events, 16 evidenced vulnerabilities
Risk register with scoring rationale and historical tracking	5 + Excel	Register with rationale per risk; append-only history log (19 entries), including re-scores

> **Headline results:** 16 risks identified — Critical 2 High 9 Medium 5 Low 0. The five quantified risks carry a combined **ALE of $2,765,843**; recommended controls costing **$11,663/year** reduce this to **$817,836**.

1. Structured Risk Identification

Three independent methods were used so that each covers the others' blind spots. **Brainstorming** captures what people who use the systems worry about. A **checklist** tests the live configuration against an industry baseline. A **SWOT analysis** looks at strategy and the outside world. Each method's results were merged into one register (1.4).

1.1 Method 1 — Facilitated brainstorming workshop

Objective	Identify risks to the confidentiality, integrity and availability of ePHI in HVMC's Azure environment and IAM processes
Format	Simulated 90-minute workshop (tabletop format), HVMC Security Monitoring Portal meeting room
Facilitator / scribe	Sabitha S Karanavar (RMF Program Lead) / Jason Park (IT Support Specialist)
Participants (8)	Denise Coleman (Security Supervisor), Anthony Ruiz (Security Officer), Kevin O'Brien (IT Manager), Fatima Ali (Systems Administrator), Sarah Chen (Physician, EHR owner), Elena Petrova (Lab Manager), David Patel (Pharmacist), Daniel Osei (HR Manager)
Pre-work	Participants received the HVMC system inventory (FIPS 199 table) and the HVMC-Prod-VNet diagram 48 hours before
Technique	**Nominal Group Technique**: silent idea writing, so senior voices don't dominate. Then round-robin sharing, affinity grouping into themes, and dot voting (3 votes each) to prioritize.
Ground rules	No criticism during generation; quantity over quality; phrase ideas as "cause → event → effect"; out-of-scope ideas go to a "parking lot", not the bin

Time	Agenda step	Facilitator action
0–10 min	Scope and rules	Present scope (Azure tenant, EHR storage, IAM), ground rules, prompt question: "What could stop us protecting patient data or delivering care?"
10–25 min	Silent generation	Each participant writes ideas on sticky notes; no discussion
25–50 min	Round-robin sharing	One idea per person per round until exhausted; scribe records verbatim
50–70 min	Affinity grouping	Group similar ideas into themes; merge duplicates; move out-of-scope ideas to parking lot
70–85 min	Dot voting	3 votes per person on themes of greatest concern
85–90 min	Close	Confirm themes, assign each to a risk ID and owner for scoring

Workshop output (raw ideas → themes → risks)

#	Raised by	Idea (as recorded)	Risk ID	Votes
B1	Sarah Chen	Clinicians receive realistic Microsoft sign-in emails; one click could give an attacker EHR access	R12	4
B2	Sarah Chen	Ransomware has hit nearby hospitals — could we restore the EHR in a day?	R05	7
B3	Anthony Ruiz	Would we even notice an intruder? Nothing alerts us today	R01	5
B4	Fatima Ali	If the storage account key leaks, can someone download records from home?	R02	4

#	Raised by	Idea (as recorded)	Risk ID	Votes
B5	Kevin O'Brien	Contractor accounts stay active after projects end	R06	1
B6	Daniel Osei	No defined consequence when staff break security rules	R14	–
B7	Elena Petrova	Staff looking up relatives' or colleagues' lab results	R13	3
B8	David Patel	Infected files uploaded from a pharmacy workstation spread to others	R11	–
B9	Denise Coleman	Who decides whether an incident is a reportable breach? We have no Privacy Officer	R16	–
B10	Kevin O'Brien	Only one admin account — if it is locked or stolen we cannot recover	R04	–
B11	Fatima Ali	Someone deletes the production resource group by mistake	R15	–
B12	David Patel	Tampered dose data in the database could harm a patient	R03	–
B13	Anthony Ruiz	Old public servers with known CVEs (Sept scan) are still unpatched	R09/R10	–
B14	Elena Petrova	LIS interface outage delays lab results	Parking lot	–
B15	Daniel Osei	Lost laptop with HR spreadsheets	Parking lot	–
B16	Sarah Chen	Azure East US region outage	Parking lot	–

Parking lot: B14 (no Azure component yet — revisit when LIS moves to cloud), B15 (endpoint scope — next semester), B16 (accepted: storage is RA-GRS geo-redundant). Votes: 24 total (8 participants × 3). The top themes were ransomware (7), undetected intrusion (5), phishing (4) and storage exposure (4).

1.2 Method 2 — Checklist (CIS Microsoft Azure Foundations Benchmark, aligned)

Checklist used	Controls selected from the CIS Microsoft Azure Foundations Benchmark areas: Identity, Microsoft Defender, Storage, Logging & Monitoring, Networking. Plus HVMC's HIPAA matrix (Risk Management Fundamentals, Part 3)
Performed by / date	Sabitha S Karanavar (reviewed by Anthony Ruiz), October 13, 2026
Method	Each item tested with a read-only Azure CLI or Microsoft Graph query against subscription "Azure subscription 1". The result is recorded as Pass or Fail, with the command output as evidence. Nothing was changed during the check.
Rule for creating a risk	Every Fail is turned into a vulnerability (Section 4.3). Fails that share a root cause become one risk.
Result	**12 Pass / 15 Fail** out of 27 checks (44% compliant)

Area	Check	Result	Evidence (live Azure)
Identity	MFA required for all users	**Pass**	Security defaults enforced; device-code sign-in blocked with AADSTS530035 during az login
Identity	Between 2 and 4 Global Administrators	**Fail**	directoryRoles: Global Administrator = 1 member (Sabitha S Karanavar)
Identity	Guest invitations restricted to admins	**Fail**	authorizationPolicy.allowInvitesFrom = everyone
Identity	Users cannot register applications	**Fail**	defaultUserRolePermissions.allowedToCreateApps = true
Identity	Users cannot create tenants	**Fail**	defaultUserRolePermissions.allowedToCreateTenants = true
Identity	No unreviewed guest accounts	**Pass**	az ad user list --filter "userType eq 'Guest'" returned 0
Identity	Custom roles grant least privilege	**Pass**	HVMC-Nurse-EHR-ReadOnly: 3 read-only storage actions
Identity	No test or shared accounts in production	**Fail**	Test Nurse - EHR has role on hvmcehrstorage

Area	Check	Result	Evidence (live Azure)
Defender	Defender for Storage enabled	**Fail**	az security pricing list: StorageAccounts = Free
Defender	Security contact email configured	**Fail**	az security contact list returned 0
Defender	Default security policy assigned	**Pass**	Policy assignment: ASC Default
Storage	Secure transfer (HTTPS) required	**Pass**	enableHttpsTrafficOnly = true
Storage	Minimum TLS version 1.2	**Pass**	minimumTlsVersion = TLS1_2
Storage	Anonymous blob access disabled	**Pass**	allowBlobPublicAccess = false
Storage	Default network access rule is Deny	**Fail**	networkRuleSet.defaultAction = Allow; publicNetworkAccess = Enabled
Storage	Shared key access disabled	**Fail**	allowSharedKeyAccess = true
Storage	Blob soft delete enabled	**Pass**	deleteRetentionPolicy enabled, 7 days (recommend 14–30)
Storage	Blob versioning enabled	**Fail**	isVersioningEnabled = null
Storage	Geo-redundant replication	**Pass**	sku = Standard_RAGRS
Logging	Activity log sent to Log Analytics	**Fail**	0 subscription diagnostic settings; 0 Log Analytics workspaces
Logging	Alerts for NSG / policy / security changes	**Fail**	az monitor activity-log alert list returned 0
Logging	Network Watcher enabled in region	**Pass**	Network Watcher present in eastus
Logging	NSG / VNet flow logs enabled	**Fail**	az network watcher flow-log list returned 0
Network	No RDP/SSH open to the internet	**Pass**	Only inbound internet rule is TCP 443 on HVMC-Web-NSG
Network	Admin access through Azure Bastion	**Pass**	HVMC-Bastion in AzureBastionSubnet 10.0.4.0/26
Network	Tiers isolated (explicit deny between subnets)	**Fail**	HVMC-Data-NSG relies on default AllowVnetInBound
Governance	Resource locks on production	**Fail**	az lock list returned 0

1.3 Method 3 — SWOT analysis

Facilitation: run as the second half of the workshop with the same participants. Strengths and Weaknesses are internal and were checked against the checklist evidence. Opportunities and Threats are external, drawn from threat intelligence and the vendor roadmap. Weaknesses and Threats become risks. Strengths are recorded as existing controls that lower likelihood. Opportunities become treatment options.

STRENGTHS (internal)

- MFA enforced for all users (security defaults)
- 10 role-based security groups; every user in exactly one
- Three-tier network: only TCP 443 open to the internet
- Admin access only through Azure Bastion
- Encryption at rest, HTTPS-only, TLS 1.2
- RA-GRS geo-redundant EHR storage
- Documented governance, IR playbook, HIPAA matrix

WEAKNESSES (internal)

- No central logging, alerting or flow logs → R01
- EHR storage open to public networks, shared keys on → R02
- Single Global Administrator → R04
- No versioning, short soft delete, no locks → R05, R15
- Defender for Cloud plans all Free → R11
- Privacy Officer vacant; no sanction policy → R16, R14

OPPORTUNITIES (external)

- Defender for Storage malware scanning (≈ $10 per account/month)
- Entra ID P1 Conditional Access and phishing-resistant MFA
- Azure Policy to enforce storage and NSG baselines automatically
- Microsoft HIPAA BAA via Product Terms
- Log Analytics / Microsoft Sentinel for monitoring

THREATS (external)

- Ransomware groups targeting hospitals → R05
- AiTM phishing kits that bypass push MFA → R12
- Insider snooping (top HIPAA complaint type) → R13
- Public exploits for legacy SSH/Apache → R09, R10
- HHS OCR penalties up to $2,190,294/yr per provision
- Third-party / contractor compromise → R06

1.4 Consolidation — which method found each risk

Risks found by more than one method get more confidence. Risks found by only one method show why using three methods matters. For example, R03 and R08 came only from the checklist, and nobody raised them in the workshop.

ID	Risk	Brainstorm	Checklist	SWOT
R01	Security incident goes undetected for months (no central logging or alerting)	●	●	●
R02	ePHI exfiltration from EHR storage over the public internet	●	●	
R03	Lateral movement from Web tier to Data tier		●	
R04	Loss or takeover of the only Global Administrator account	●	●	●
R05	Ransomware or malicious deletion destroys EHR data	●		●
R06	Contractor retains access after engagement ends; no BAA	●	●	
R07	Shared test account in production can read ePHI		●	
R08	Consent phishing or rogue app via open tenant settings		●	
R09	Remote code execution via OpenSSH 6.6.1p1 (CVE-2023-38408, CVSS 9.8)		●	
R10	Remote code execution via Apache 2.4.7 mod_lua (CVE-2021-44790, CVSS 9.8)		●	
R11	Malware uploaded to EHR storage is not detected		●	●
R12	Clinician credentials stolen by MFA-bypass (AiTM) phishing	●		●
R13	Workforce member views patient records without a care need (snooping)	●		●
R14	Workforce violations go unpunished; training not tracked	●	●	
R15	Accidental deletion of production network or storage		●	
R16	Breach notification deadline missed (no Privacy Officer)	●		●
	Total per method	**9**	**12**	**7**

2. Qualitative Analysis — 5×5 Risk Matrix

Risk score = Likelihood × Impact (1–25). Ratings use the HVMC bands set in Risk Management Fundamentals: Critical 20–25, High 12–19, Medium 6–11, Low 1–5. Likelihood is judged over 12 months. Impact is the **worst** of the four columns below, so a risk with any patient-safety effect is rated on that effect.

2.1 Likelihood scale

Score	Level	Annual probability	Description
1	Rare	< 5% per year (once in 20+ years)	No known threat activity; strong preventive controls
2	Unlikely	5–20% per year	Possible but requires uncommon conditions or skill
3	Possible	20–50% per year	Seen in healthcare peers; partial controls in place
4	Likely	50–90% per year	Active threat campaigns; control missing or weak
5	Almost certain	> 90% per year (multiple times)	Already occurring or trivially exploitable

2.2 Impact scale

Score	Level	Financial	ePHI records	Downtime	Patient safety
1	Negligible	< $10K	No PHI	< 1 hour	None
2	Minor	$10K–$100K	< 50 records	1–4 hours	None
3	Moderate	$100K–$500K	50–499 records	4–24 hours	Care delayed, no harm
4	Major	$500K–$2M	500–9,999 records (HHS + media notice)	1–3 days	Possible temporary harm
5	Severe	> $2M	10,000+ records	> 3 days EHR outage	Serious patient harm

500 records is the HIPAA threshold for notifying HHS immediately and alerting the media (§164.406, §164.408).

2.3 Heat map

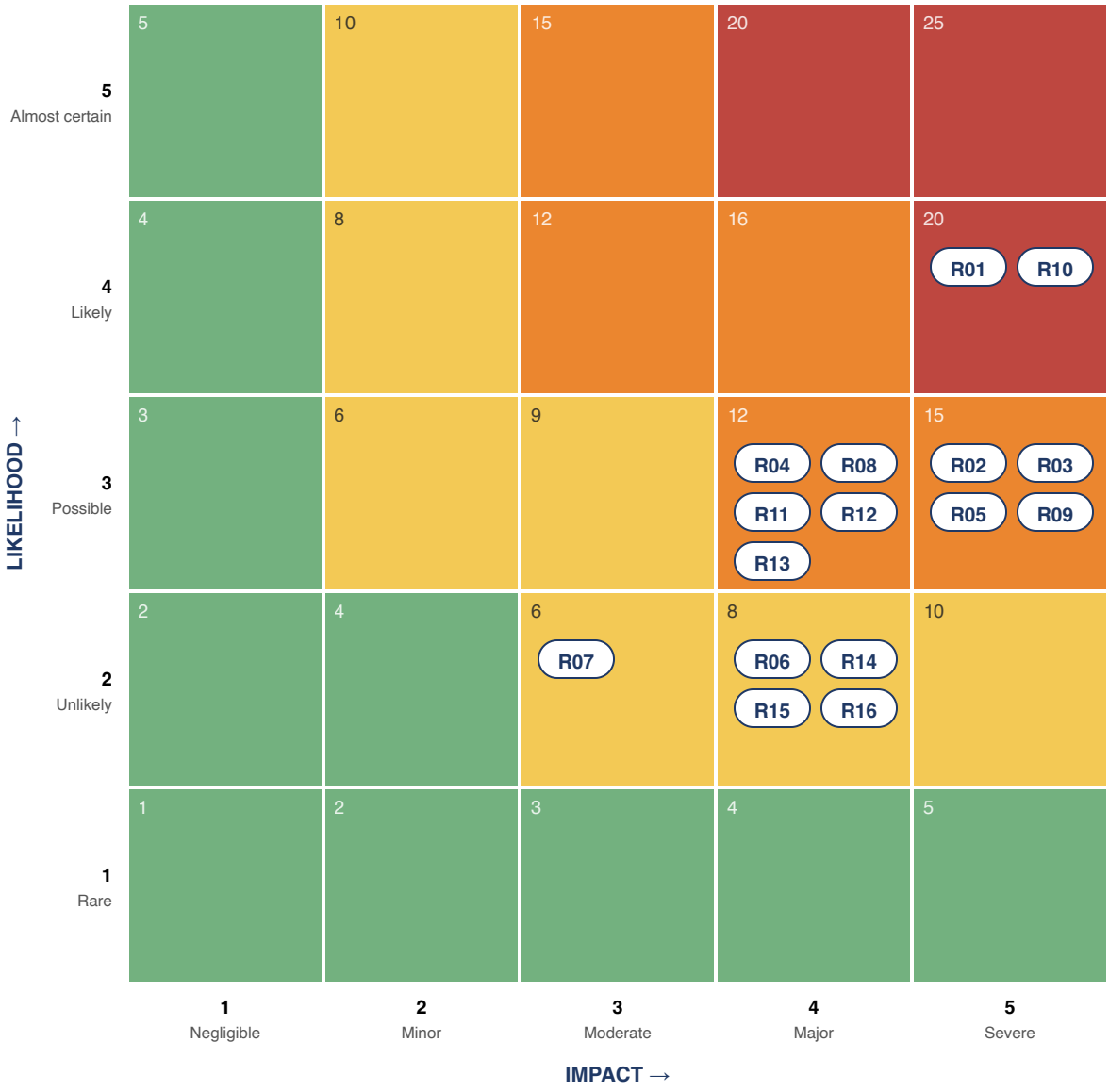


Figure 1 — HVMC 5×5 risk matrix with all 16 risks plotted (cell number = score).

2.4 Ranked results

ID	Risk	L	I	Score	Rating
R01	Security incident goes undetected for months (no central logging or alerting)	4	5	**20**	Critical
R10	Remote code execution via Apache 2.4.7 mod_lua (CVE-2021-44790, CVSS 9.8)	4	5	**20**	Critical
R02	ePHI exfiltration from EHR storage over the public internet	3	5	**15**	High
R03	Lateral movement from Web tier to Data tier	3	5	**15**	High
R05	Ransomware or malicious deletion destroys EHR data	3	5	**15**	High
R09	Remote code execution via OpenSSH 6.6.1p1 (CVE-2023-38408, CVSS 9.8)	3	5	**15**	High
R04	Loss or takeover of the only Global Administrator account	3	4	**12**	High

ID	Risk	L	I	Score	Rating
R08	Consent phishing or rogue app via open tenant settings	3	4	**12**	High
R11	Malware uploaded to EHR storage is not detected	3	4	**12**	High
R12	Clinician credentials stolen by MFA-bypass (AiTM) phishing	3	4	**12**	High
R13	Workforce member views patient records without a care need (snooping)	3	4	**12**	High
R06	Contractor retains access after engagement ends; no BAA	2	4	**8**	Medium
R14	Workforce violations go unpunished; training not tracked	2	4	**8**	Medium
R15	Accidental deletion of production network or storage	2	4	**8**	Medium
R16	Breach notification deadline missed (no Privacy Officer)	2	4	**8**	Medium
R07	Shared test account in production can read ePHI	2	3	**6**	Medium

3. Quantitative Analysis — ALE and EMV

3.1 Formulas and supporting data

Term	Definition / source
Asset Value (AV) — EHR data	**$9,610,294** = $7,420,000 average healthcare breach cost (IBM *Cost of a Data Breach 2025*; healthcare highest industry for 12+ years) + $2,190,294 HIPAA maximum annual penalty per identical provision (HHS 2025 inflation adjustment, published January 2026)
Exposure Factor (EF)	Share of the asset value lost in one event (0–1). Set from scenario scope; see each row.
Single Loss Expectancy (SLE)	SLE = AV × EF
Annual Rate of Occurrence (ARO)	Expected events per year, matching the likelihood score (L3 ≈ 0.20–0.35, L4 ≈ 0.60)
Annual Loss Expectancy (ALE)	ALE = SLE × ARO
Return on Security Investment (ROSI)	(ALE before − ALE after − annual control cost) ÷ annual control cost
Expected Monetary Value (EMV)	EMV = Σ (probability × monetary outcome) across all branches of a decision
Other inputs	Control costs are approximate Azure list prices plus internal labor at $75/hour. Verify them in the Azure Pricing Calculator before budgeting. Healthcare breach lifecycle: 279 days (IBM 2025). This is used to justify a high EF for R01.

3.2 Annual Loss Expectancy — top five risks

Risk	EF	SLE	ARO	ALE (now)	EF / ARO after	ALE (after)	Control cost /yr	ROSI
R01 Undetected incident (279-day dwell)	0.15	$1,441,544	0.60	**$864,926**	0.06 / 0.60	$345,971	$2,131	243×
R02 EHR storage exfiltration	0.25	$2,402,574	0.25	**$600,643**	0.25 / 0.05	$120,129	$1,300	369×
R05 Ransomware / deletion of EHR data	0.55	$5,285,662	0.20	**$1,057,132**	0.15 / 0.20	$288,309	$2,400	319×
R12 AiTM phishing of a clinician	0.05	$480,515	0.35	**$168,180**	0.05 / 0.08	$38,441	$2,232	57×
R13 Insider snooping incident	0.026	$249,868	0.30	**$74,960**	0.026 / 0.10	$24,987	$3,600	13×
Total				**$2,765,843**		**$817,836**	**$11,663**	

Risk	Control assumed	Cost basis and scenario reasoning
R01	Log Analytics + diagnostic settings + alert rules	~10 GB/month ingestion ≈ $331/yr + 24 h setup × $75. EF 0.15: undetected dwell multiplies breach cost. Logging and alerts cut detection from months to days, so EF drops to 0.06; ARO is unchanged because logging detects attacks rather than prevents them.
R02	Deny public access, disable shared key, private endpoint	Private endpoint ≈ $90/yr + 16 h × $75. EF 0.25: a leaked key exposes roughly a quarter of records before the key is rotated. Private access cuts ARO from 0.25 to 0.05; EF is unchanged.
R05	Versioning, 30-day soft delete, locks, restore test	Version storage ≈ $600/yr + 24 h restore test × $75. EF 0.55: full rebuild, downtime and diversion of ambulances. With versioning, EF drops to 0.15, leaving downtime only.

Risk	Control assumed	Cost basis and scenario reasoning
R12	Entra ID P1 Conditional Access for 31 users	31 users × $6/month × 12. EF 0.05: one clinician's access, so a limited set of records. Conditional Access cuts ARO from 0.35 to 0.08.
R13	EHR access auditing + monthly owner review	4 h/month × $75 × 12. EF 0.026 ≈ $250K: investigation, notification and an OCR Tier 2 penalty. Auditing deters snooping and catches it early, so ARO drops to 0.10.

Interpretation: all five controls together cost $11,663 per year and reduce expected annual loss by $1,948,007. Every control has a ROSI far above 1. The figures are large because AV uses the industry-average breach cost. HVMC is a small simulated hospital, so the absolute dollars are indicative, but the **ranking** (R05 > R01 > R02 > R12 > R13) and the case for acting hold even if AV were 10× smaller.

3.3 Expected Monetary Value — ransomware decision (R05)

Decision: should HVMC spend $2,400 per year on the G8 recovery controls, or accept the risk? Probability of a ransomware attack in the year = 0.2 (likelihood 3).

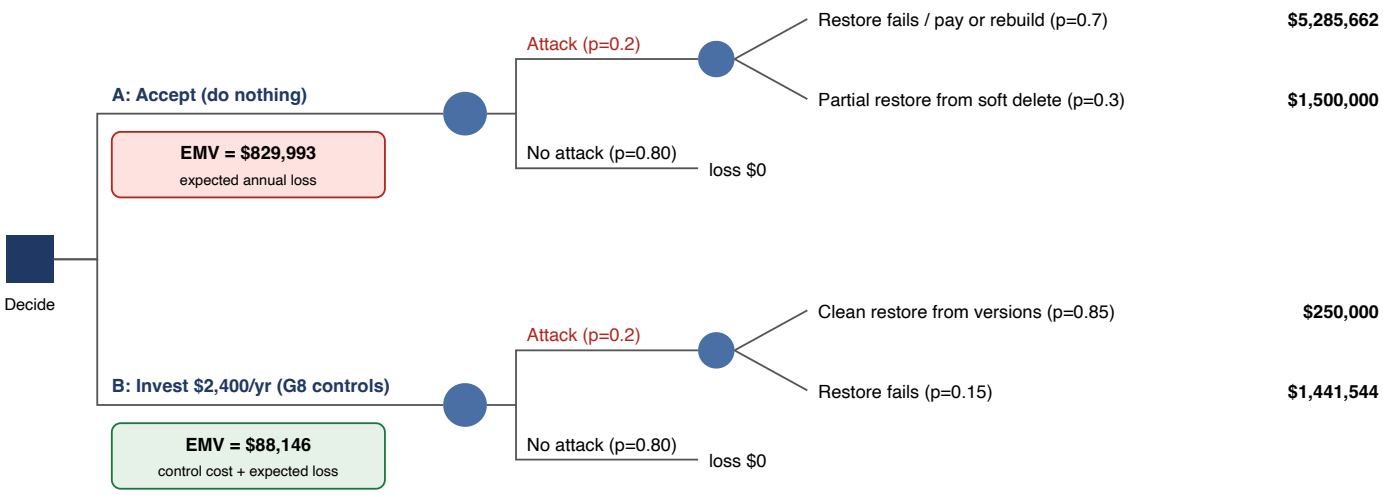


Figure 2 — EMV decision tree for R05. Square = decision, circle = chance node.

Option	Calculation	EMV
A — Accept	0.2 × (0.7 × $5,285,662 + 0.3 × $1,500,000)	**$829,993**
B — Invest	$2,400 + 0.2 × (0.85 × $250,000 + 0.15 × $1,441,544)	**$88,146**
Difference	Option B lowers expected cost by	**$741,846**

Decision: choose Option B. Break-even: Option B stays cheaper as long as the chance of an attack is above 0.06% per year, far below any realistic estimate for a hospital.

3.4 EMV contingency reserve (risk exposure)

Summing probability × impact across the quantified risks gives the amount HVMC should hold in reserve, or insure through cyber insurance (risk transfer), for the current year if no controls are added:

Risk	Probability (ARO)	Impact (SLE)	EMV
R01 Undetected incident (279-day dwell)	0.60	$1,441,544	$864,926
R02 EHR storage exfiltration	0.25	$2,402,574	$600,643
R05 Ransomware / deletion of EHR data	0.20	$5,285,662	$1,057,132
R12 AiTM phishing of a clinician	0.35	$480,515	$168,180
R13 Insider snooping incident	0.30	$249,868	$74,960
Total exposure			**$2,765,843**

4. Threat and Vulnerability Assessment

Method: **NIST SP 800-30 Rev. 1** (Guide for Conducting Risk Assessments). Steps: identify threat sources, identify threat events (mapped to MITRE ATT&CK), identify vulnerabilities with evidence, then pair each threat with a vulnerability to form a risk (Section 5).

4.1 Threat sources

Source (SP 800-30 type)	Example for HVMC	Capability	Intent	Targeting	Relevance
Adversarial — outsider (organized crime)	Ransomware affiliates, AiTM phishing operators	High	High	High	**Confirmed**
Adversarial — outsider (opportunistic)	Internet scanners exploiting known CVEs and open storage	Moderate	Moderate	Low	**Confirmed**
Adversarial — insider	Workforce member snooping on patient records	Moderate	Moderate	High	**Expected**
Adversarial — trusted third party	Contractor (Carlos Diaz) account misuse or compromise	Moderate	Low	Moderate	**Possible**
Accidental — privileged user	Administrator deletes or misconfigures a resource	n/a	n/a	n/a	**Expected**
Structural — cloud provider	Azure East US region outage	n/a	n/a	n/a	**Mitigated (RA-GRS)**

4.2 Threat events (MITRE ATT&CK)

ATT&CK technique	Threat event at HVMC	Exploits	Risk
T1566 Phishing; T1557 Adversary-in-the-Middle	Clinician enters credentials and MFA code into a proxy login page	V12	R12
T1078.004 Valid Accounts: Cloud	Attacker or ex-contractor signs in with real credentials	V04, V06, V07	R04, R06, R07
T1528 Steal Application Access Token	User consents to a malicious app registered in or invited into the tenant	V08	R08
T1530 Data from Cloud Storage	Bulk download of EHR blobs with a leaked key	V02	R02
T1190 Exploit Public-Facing Application	RCE on legacy SSH / Apache server	V09, V10	R09, R10
T1021 Remote Services (lateral movement)	Pivot from web server to SQL on 10.0.3.0/24	V03	R03
T1105 Ingress Tool Transfer	Malware uploaded into EHR storage and opened by staff	V11	R11

ATT&CK technique	Threat event at HVMC	Exploits	Risk
T1486 Data Encrypted for Impact; T1485 Data Destruction	Ransomware encrypts or deletes EHR blobs	V05, V15	R05, R15
T1562.008 Impair Defenses: Disable Cloud Logs	Attacker activity leaves no retained trail	V01	R01

4.3 Vulnerability findings

ID	Vulnerability and evidence	Affected asset	Severity	Risk
V01	0 Log Analytics workspaces, 0 activity-log diagnostic settings, 0 alert rules, 0 NSG flow logs	All Azure resources	Critical	R01
V02	public network access Enabled, firewall default Allow, shared-key access enabled	hvmcehrstorage (ePHI)	High	R02
V03	HVMC-Data-NSG has no deny rule; default AllowVnetInBound (65000) permits Web→Data on any port	HVMC-Data-Subnet (SQL 1433)	High	R03
V04	1 Global Administrator, no break-glass account, same person is subscription Owner	Entra ID tenant	High	R04
V05	blob versioning off, soft delete only 7 days, 0 resource locks, restore never tested	hvmcehrstorage (ePHI)	High	R05
V06	Carlos Diaz account has no expiry date; no business associate agreement on file	VPN Portal	Medium	R06
V07	Test Nurse - EHR holds HVMC-Nurse-EHR-ReadOnly on hvmcehrstorage	hvmcehrstorage (ePHI)	Medium	R07
V08	any user can register apps and create tenants; guest invites allowed from everyone	Entra ID tenant	High	R08
V09	decade-old OpenSSH with ssh-agent forwarding flaw	Legacy public server (scanme.nmap.org lab target)	High	R09
V10	Apache 2.4.7 with public exploits available	Legacy public server (scanme.nmap.org lab target)	Critical	R10
V11	all Defender for Cloud workload plans on Free tier; 0 security contacts configured	hvmcehrstorage (ePHI)	High	R11
V12	security defaults allow push/OTP MFA; no Conditional Access or phishing-resistant MFA	EHR access (Doctors/Nursing groups)	High	R12
V13	no record-level access auditing or monthly access-log review	EHR (12 clinical users with RW)	High	R13
V14	no sanction policy; HIPAA training completion not recorded	Workforce	Medium	R14
V15	0 resource locks on the production resource group	HVMC-CloudSecurity-RG	Medium	R15
V16	Privacy Officer role vacant	Regulatory compliance	Medium	R16

V01–V08, V11 and V15 were confirmed live on October 13, 2026 (Section 1.2). V09–V10 come from the September 8 Nmap/vulners scan. V12–V14 and V16 are process findings from the workshop and the HIPAA matrix.

4.4 Key findings

- **Detection is the biggest weakness.** Workspaces, alert rules, flow logs and security contacts all read zero, so even a well-protected environment would not notice a compromise (R01, Critical).
- **Identity is strong at the front door but weak behind it.** MFA is enforced, but there is one Global Admin, tenant settings are open (app registration, guest invites) and there is no Conditional Access.
- **The EHR store is encrypted but not isolated.** Encryption and TLS pass, but public network access and shared keys mean one leaked key exposes ePHI.
- **Network design is good in intent but incomplete.** Allow rules are tight, but there is no explicit deny, so the default VNet rule undoes the segmentation.

5. Risk Register

The full working register is in **HVMC_Risk_Register.xlsx**. Its sheets:

Sheet	Purpose and tracking features
Register	One row per risk. Score and Rating are **formulas** (L × I), so changing L or I re-rates the risk automatically. Status has a drop-down (Open / In Progress / Mitigated / Accepted / Closed). Includes Date Opened, Last Reviewed and Next Review (+30 days, formula).
History	**Append-only change log**: every new risk, re-score and status change gets a dated row with old value, new value, who changed it and why. Never edit old rows; add a new one. This gives an audit trail for HIPAA §164.316(b) documentation.
Heat Map	5×5 matrix that counts risks per cell with COUNTIFS. Updates automatically when the register changes.
ALE Calculator	AV, EF, ARO inputs with SLE/ALE/ROSI formulas. Change an input to test "what if" scenarios.
Checklist	The 27 CIS-aligned checks with evidence. Re-run monthly to see the trend.
Scales	Likelihood and impact definitions, so every reviewer scores the same way.

5.1 Register summary with scoring rationale

ID	Risk	L	I	Rating	Scoring rationale	Owner	Treatment
R01	Security incident goes undetected for months (no central logging or alerting)	4	5	Critical 20	L4: incidents are likely in a year, and with no alerting none would be seen; IBM 2025 puts the healthcare breach lifecycle at 279 days. I5: undetected ePHI exposure reaches 10,000+ records.	Fatima Ali	Mitigate: Log Analytics + diagnostic settings + alert rules (G1) Target 2026-10-24
R10	Remote code execution via Apache 2.4.7 mod_lua (CVE-2021-44790, CVSS 9.8)	4	5	Critical 20	L4: public exploit code exists and the service faces the internet. I5: RCE on a public web server.	Kevin O'Brien	Mitigate: upgrade Apache, disable mod_lua, WAF in front Target 2026-10-31
R02	ePHI exfiltration from EHR storage over the public internet	3	5	High 15	L3: storage endpoint is reachable from anywhere; a leaked key alone is enough. I5: whole EHR store exposed.	Fatima Ali	Mitigate: deny public access, disable shared key, private endpoint (G2) Target 2026-10-24
R03	Lateral movement from Web tier to Data tier	3	5	High 15	L3: needs a web-tier compromise first (internet-facing on 443). I5: direct path to the database holding ePHI.	Fatima Ali	Mitigate: Deny-All-VNet-Inbound rule priority 4000 on Data and App NSGs (G3) Target 2026-10-17
R05	Ransomware or malicious deletion destroys EHR data	3	5	High 15	L3: ransomware is the top healthcare threat. I5: >3 days EHR outage and patient-safety impact. Re-scored from 8 (G8) after threat assessment.	Fatima Ali	Mitigate: versioning, 30-day soft delete, immutability, resource locks, restore test (G8) Target 2026-10-31
R09	Remote code execution via OpenSSH 6.6.1p1 (CVE-2023-38408, CVSS 9.8)	3	5	High 15	L3: needs agent forwarding to an attacker host. I5: full host compromise. Carried from Sept 8 report and re-scored on the 5×5 scale.	Kevin O'Brien	Mitigate: upgrade OpenSSH, disable agent forwarding Target 2026-10-31

ID	Risk	L	I	Rating	Scoring rationale	Owner	Treatment
R04	Loss or takeover of the only Global Administrator account	3	4	High 12	L3: one account, used daily. I4: takeover gives full control; lockout halts all admin and recovery.	Sabitha S Karanavar	Mitigate: break-glass account + second admin via PIM (G4) Target 2026-10-17
R08	Consent phishing or rogue app via open tenant settings	3	4	High 12	L3: illicit-consent attacks are common against Microsoft 365/Entra. I4: app could read user data without MFA prompts.	Sabitha S Karanavar	Mitigate: restrict app registration, tenant creation and guest invites to admins Target 2026-10-24
R11	Malware uploaded to EHR storage is not detected	3	4	High 12	L3: clinical files arrive from many devices. I4: malware spreads to clinician workstations; nobody is notified.	Denise Coleman	Mitigate: Defender for Storage + security contact email Target 2026-10-31
R12	Clinician credentials stolen by MFA-bypass (AiTM) phishing	3	4	High 12	L3: AiTM kits target healthcare routinely. I4: attacker gets one clinician's EHR read/write access.	Denise Coleman	Mitigate: Entra ID P1 Conditional Access + phishing-resistant MFA for clinical groups Target 2026-11-30
R13	Workforce member views patient records without a care need (snooping)	3	4	High 12	L3: most common HIPAA complaint type. I4: OCR investigation, sanctions, loss of patient trust.	Denise Coleman	Mitigate: EHR access auditing + monthly review by system owner Target 2026-11-30
R06	Contractor retains access after engagement ends; no BAA	2	4	Medium 8	L2: one contractor, read-only VPN. I4: unmanaged third-party access is a HIPAA violation even without misuse.	Kevin O'Brien	Mitigate: account end date + access review; sign BAA (G6) Target 2026-10-17
R14	Workforce violations go unpunished; training not tracked	2	4	Medium 8	L2: policy gap, not an active threat. I4: required HIPAA standard; OCR penalty exposure.	Daniel Osei	Mitigate: write sanction policy, track training (G5) Target 2026-10-31
R15	Accidental deletion of production network or storage	2	4	Medium 8	L2: few admins, changes are infrequent. I4: deleting the VNet or storage takes the patient portal offline.	Kevin O'Brien	Mitigate: CanNotDelete lock on HVMC-CloudSecurity-RG Target 2026-10-17
R16	Breach notification deadline missed (no Privacy Officer)	2	4	Medium 8	L2: needs a breach first. I4: missing the 60-day §164.404 deadline adds a separate violation.	Denise Coleman	Mitigate: designate a Privacy Officer and a breach-assessment procedure Target 2026-11-30
R07	Shared test account in production can read ePHI	2	3	Medium 6	L2: MFA required, account rarely used. I3: read-only, but not traceable to a person.	Sabitha S Karanavar	Mitigate: move to non-production or remove role when testing ends (G7) Target 2026-10-24

5.2 Historical tracking — change log

Date	Risk	Event	Score old → new	Changed by	Reason
2026-09-08	R09	Opened	– → Critical (legacy)	Sabitha S Karanavar	Identified in Apply Vulnerability Assessment Techniques scan; rated with Sept impact-floor method
2026-09-08	R10	Opened	– → Critical (legacy)	Sabitha S Karanavar	Identified in Apply Vulnerability Assessment Techniques scan; rated with Sept impact-floor method

Date	Risk	Event	Score old → new	Changed by	Reason
2026-10-13	R01	Opened	– → 20	Sabitha S Karanavar	HIPAA matrix gap G1 (audit controls)
2026-10-13	R02	Opened	– → 15	Sabitha S Karanavar	HIPAA matrix gap G2 (storage public access)
2026-10-13	R03	Opened	– → 15	Sabitha S Karanavar	HIPAA matrix gap G3 (Data NSG)
2026-10-13	R04	Opened	– → 12	Sabitha S Karanavar	HIPAA matrix gap G4 (single Global Admin)
2026-10-13	R05	Opened	– → 8	Sabitha S Karanavar	HIPAA matrix gap G8 (versioning off, DR untested)
2026-10-13	R06	Opened	– → 8	Sabitha S Karanavar	HIPAA matrix gap G6 (contractor)
2026-10-13	R07	Opened	– → 6	Sabitha S Karanavar	HIPAA matrix gap G7 (test account)
2026-10-13	R14	Opened	– → 8	Sabitha S Karanavar	HIPAA matrix gap G5 (sanction policy)
2026-10-13	R09	Re-scored	Critical (legacy) → 15	Anthony Ruiz	Converted to HVMC 5×5 scale (L3×I5). Likelihood Medium → 3.
2026-10-13	R10	Re-scored	Critical (legacy) → 20	Anthony Ruiz	Converted to HVMC 5×5 scale (L4×I5). Public exploit code raises likelihood to 4.
2026-10-13	R05	Re-scored	8 → 15	Anthony Ruiz	Threat assessment: ransomware is the leading healthcare threat (L2→3) and EHR loss is patient-safety impact (I4→5).
2026-10-13	R08	Opened	– → 12	Anthony Ruiz	CIS checklist: open app registration and guest invites
2026-10-13	R11	Opened	– → 12	Anthony Ruiz	CIS checklist: Defender plans Free, no security contact
2026-10-13	R12	Opened	– → 12	Anthony Ruiz	Brainstorming + SWOT: AiTM phishing of clinicians
2026-10-13	R13	Opened	– → 12	Anthony Ruiz	Brainstorming: insider snooping on patient records
2026-10-13	R15	Opened	– → 8	Anthony Ruiz	CIS checklist: no resource locks
2026-10-13	R16	Opened	– → 8	Anthony Ruiz	Brainstorming + SWOT: Privacy Officer vacancy

Two re-scores show tracking in action: R09/R10 were moved from the September "impact-floor" method to the 5×5 scale, and R05 was raised from 8 to 15 after the threat assessment. When G1–G8 fixes are applied, each will add a "Status → Mitigated" row and a residual re-score.

Conclusion

Three identification methods produced 16 consolidated risks. The checklist uncovered configuration weaknesses nobody raised in the workshop, and the workshop raised human and process risks no checklist would catch. The 5×5 analysis rates 2 risks Critical and 9 High. ALE analysis puts current expected annual loss for the top five at $2,765,843, reducible to $817,836 for $11,663 per year. The EMV decision tree supports funding ransomware recovery controls. Every finding is traceable from evidence (Section 1.2/4.3) to a register entry with a scored rationale and a dated history.

References

- NIST SP 800-30 Rev. 1, *Guide for Conducting Risk Assessments* (2012).
- CIS Microsoft Azure Foundations Benchmark (Center for Internet Security).
- MITRE ATT&CK Enterprise Matrix, attack.mitre.org.
- IBM Security, *Cost of a Data Breach Report 2025* — healthcare average $7.42M; 279-day lifecycle (as summarized by HIPAA Journal).
- HHS, Annual Civil Monetary Penalties Inflation Adjustment (2025 amounts, published January 2026) — annual cap $2,190,294.
- 45 CFR §164.308(a)(1)(ii)(A)–(B), §164.316(b), §164.404–408.
- HVMC project evidence: HVMC_Risk_Management_Fundamentals.pdf; Risk_Management_Rubric_Final_Report.pdf (Sept 8, 2026); Azure CLI output, October 13, 2026.